

Siber Saldırı Çerçevesleri ve Göstergeleri Üzerine Bir Bilgilendirme Notu

Özet

Bu bilgilendirme notu, siber saldırıların yapısını, savunma stratejilerini ve saldırı göstergelerini açıklayan temel kavramları sentezlemektedir. Ana bulgular üç temel tema etrafında toplanmaktadır: Siber "Kill Chain" modeli, MITRE tarafından geliştirilen savunma odaklı bilgi tabanları ve saldırı göstergelerinin (IoC) savunmadaki rolü.

Cyber Kill Chain, bir saldırının askeri bir konseptten uyarlanmış, keşiften nihai hedefe ulaşmaya kadar olan aşamalı yapısını ortaya koyar. Bu model, saldırganların hedef belirleme, silahlanma, teslimat, sömürü, kurulum, komuta-kontrol ve eyleme geçme adımlarını sistematik bir şekilde inceler. Bu aşamaları anlamak, savunmacıların saldırıları tespit etme ve engelleme yeteneklerini artırır.

MITRE, siber güvenlik topluluğuna paha biçilmez kaynaklar sunan bir kuruluştur. En bilinen katkısı, gerçek dünya gözlemlerine dayanan rakip taktik ve tekniklerini içeren küresel bir bilgi tabanı olan **MITRE ATT&CK®** çerçevesidir. ATT&CK®, CVE (Common Vulnerabilities and Exposures) listesi gibi diğer kaynaklarla birlikte, SOC analistleri ve siber tehdit avcıları gibi profesyoneller için temel bir araç seti oluşturur.

Son olarak, saldırıların ardında bıraktığı dijital izler olan **saldırı göstergeleri** ele alınmaktadır. Hash değerleri, IP adresleri ve alan adları gibi göstergeler, bir sistemin ele geçirilip geçirilmediğini anlamada kritik rol oynar. Her bir göstergenin savunma açısından farklı bir değeri vardır; örneğin, bir IP adresini engellemek geçici bir çözümken, bir saldırganın kullandığı araçların hash değerlerini tespit etmek daha kalıcı bir savunma sağlayabilir. Bu kavramlar, modern siber savunma stratejilerinin temel taşlarını oluşturmaktadır.

Siber Saldırı Yaşam Döngüsü: Cyber Kill Chain Modeli

"Kill chain" (öldürme zinciri), kökeni askeri terminolojiye dayanan ve bir saldırının yapısını tanımlayan bir konsepttir. Bu yapı temel olarak hedefin tespiti, hedefe saldırma kararı ve emri, son olarak da hedefin imhası adımlarından oluşur. Siber güvenlik alanında bu model, bir saldırganın hedefine ulaşmak için izlediği adımları tanımlamak için kullanılır.

1. Keşif (Reconnaissance)

Bu aşama, bir sisteme veya kurbanı yönelik saldırının araştırma ve planlama safhasıdır. Saldırganlar bu aşamayı, sonraki adımlarını şekillendirmek üzere hedefleri hakkında bilgi toplamak için kullanırlar.

- **Toplanan Bilgiler:** Altyapı detayları, çalışan verileri, iş süreçleri ve dışı açık teknolojiler gibi veriler toplanabilir.
- **Yöntem:** Keşif genellikle pasif bir süreçtir ve hedef tarafından tespit edilmesi zordur.
- **Örnek:** E-posta adreslerinin toplanması (email harvesting), saldırıların ortalama (phishing) saldırıları düzenlemek için kullandığı bir yöntemdir. Saldırganlar bu amaçla geniş bir araç yelpazesine sahiptir.

2. Silahlandırma (Weaponization)

Bu, saldırıda kullanılacak kötü amaçlı içeriğin (payload) oluşturulduğu aşamadır.

- **Malware (Kötü Amaçlı Yazılım):** Bir bilgisayara zarar vermek, işleyişini bozmak veya yetkisiz erişim sağlamak için tasarlanmış program veya yazılımdır.
- **Exploit (Sömürü Kodu):** Bir uygulama veya sistemdeki bir güvenlik açığından veya kusurdan yararlanan program veya koddur.
- **Payload (Yük):** Saldırganın hedef sistem üzerinde çalıştırdığı kötü amaçlı koddur.

3. Teslimat (Delivery)

Oluşturulan kötü amaçlı yükün (payload) hedefe iletilmesi için kullanılan yöntemdir.

4. Sömürü (Exploitation)

Saldırganın kodunun hedef sistemde yürütüldüğü ve bilinen bir güvenlik açığından faydalandığı andır. Bu aşamada dikkat edilmesi gereken belirtiler şunlardır:

- Beklenmedik süreçlerin başlaması.
- Kayıt defteri (registry) değişiklikleri veya yeni hizmetlerin oluşturulması.
- Sistem günlüklerinde şüpheli komut satırı argümanlarının bulunması.

5. Kurulum (Installation)

Saldırgan, sisteme eriştikten sonra bağlantıyı kaybetmesi veya tespit edilip ilk erişiminin kaldırılması durumunda sisteme yeniden bağlanmak isteyecektir. Bu noktada saldırı, **kalıcı bir arka kapı (persistent backdoor)** kurma ihtiyacı duyar.

- **Arka Kapı (Backdoor):** Saldırganın güvenlik önlemlerini atlamasına ve erişimini gizlemesine olanak tanıyan bir erişim noktasıdır.
- **Kalıcılık:** Kalıcı bir arka kapı, saldırının geçmişte ele geçirdiği bir sisteme, güvenlik açığı yamalanmış olsa bile, tekrar erişmesine olanak tanır.

6. Komuta ve Kontrol (C2 - Command & Control)

Kurban makine ile saldırgan arasında kurulan iletişim kanalıdır. Bu kanal üzerinden saldırgan, ele geçirdiği sisteme komutlar gönderir ve veri alır.

7. Eylem (Action)

Bu son aşamada, saldırgan artık hedefine ulaşmış olup sistem üzerinde istediği eylemleri gerçekleştirebilir. Bu, veri sızdırmadan sistemi sabote etmeye kadar geniş bir yelpazeyi kapsayabilir.

MITRE Tarafından Sağlanan Temel Güvenlik Kaynakları

MITRE, yalnızca siber güvenlik alanında değil, aynı zamanda yapay zeka, sağlık bilişimi ve uzay güvenliği gibi birçok alanda "ulusun güvenliği, istikrarı ve refahı" için araştırmalar yapan bir kuruluştur. Siber güvenlik alanında uzun süredir bulunan profesyoneller, MITRE'ı genellikle bir zafiyet için exploit ararken başvurulan **CVE (Common Vulnerabilities and Exposures)** listesiyle ilişkilendirir. Ancak MITRE'in topluluğa katkıları bununla sınırlı değildir.

MITRE tarafından güvenlik topluluğuna sunulan bazı temel araçlar ve kaynaklar şunlardır:

- **ATT&CK® (Adversarial Tactics, Techniques, and Common Knowledge) Framework:** Gerçek dünya gözlemlerine dayanan, rakip taktik ve tekniklerinin küresel olarak erişilebilir bir bilgi tabanıdır.
- **CAR (Cyber Analytics Repository) Knowledge Base:** Siber analitik raporları için bir bilgi deposu.
- **ENGAGE:** Saldırganlarla etkileşim planlaması ve operasyonları için bir çerçeve.
- **D3FEND (Detection, Denial, and Disruption Framework Empowering Network Defense):** Ağ savunmasını güçlendiren tespit, engelleme ve bozma teknikleri çerçevesi.
- **AEP (ATT&CK Emulation Plans):** ATT&CK tabanlı saldırı emülasyon planları.

Bu kaynaklar, dünya çapındaki güvenlik ürünü satıcıları ve güvenlik ekipleri tarafından "kötülükle mücadeleye günlük çabalar için paha biçilmez" olarak kabul edilmektedir. Özellikle SOC analisti, tespit mühendisi veya siber tehdit analisti gibi rollere geçiş yapmak isteyenler için bu araçlar ve kaynaklar hakkında bilgi sahibi olmak bir zorunluluktur.

Saldırı Göstergeleri ve Savunma Değeri

Saldırı göstergeleri (Indicators of Compromise - IoC), bir ağda veya sistemde potansiyel bir kötü amaçlı aktiviteyi işaret eden adli tıp verileridir. Bu göstergelerin tespiti, savunmacıların saldırıları anlamasına ve bunlara karşı önlem almasına yardımcı olur.

Hash Değerleri (Hash Values)

Microsoft'a göre hash değeri, "veriyi benzersiz şekilde tanımlayan" sabit uzunlukta bir sayısal değerdir.

- **Yaygın Algoritmalar:** MD5, SHA1, SHA2.
- **Kullanım:** Kötü amaçlı yazılımlara ait dosyaların hash değerleri, bu dosyaları kesin olarak tanımlamak için kullanılır.
- **Doğrulama Araçları:** VirusTotal ve Metadefender Cloud - OPSWAT gibi çeşitli çevrimiçi araçlar, hash değerlerini aratmak için kullanılabilir.

IP Adresleri (IP Addresses)

IP adresi, "bir ağa bağlı herhangi bir cihazı tanımlamak için" kullanılır. Bu cihazlar masaüstü bilgisayarlardan sunuculara ve hatta CCTV kameralarına kadar çeşitlilik gösterebilir.

- **Savunma Yöntemi:** Savunma açısından, bir saldırganın kullandığı IP adreslerini bilmek değerlidir. Yaygın bir taktik, bu IP adreslerinden gelen istekleri güvenlik duvarı seviyesinde engellemek, düşürmek veya reddetmektir.
- **Zayıflık:** Bu taktik genellikle kusursuz değildir, çünkü deneyimli bir saldırganın yeni bir genel IP adresi kullanarak bu engeli aşması oldukça basittir.

Alan Adları (Domain Names)

Alan adları, "bir IP adresini basitçe bir metin dizisine eşlemek" olarak düşünülebilir. Bir alan adı, bir alan ve bir üst düzey alan (örneğin, evilcorp.com) veya bir alt alan, ardından bir alan ve üst düzey alan (örneğin, tryhackme.evilcorp.com) içerebilir.

- **Kullanım:** Saldırganlar, komuta ve kontrol sunucularına veya ortalama sitelerine erişim için alan adlarını kullanır. Bu alan adlarının tespiti ve engellenmesi, savunmada önemli bir adımdır.